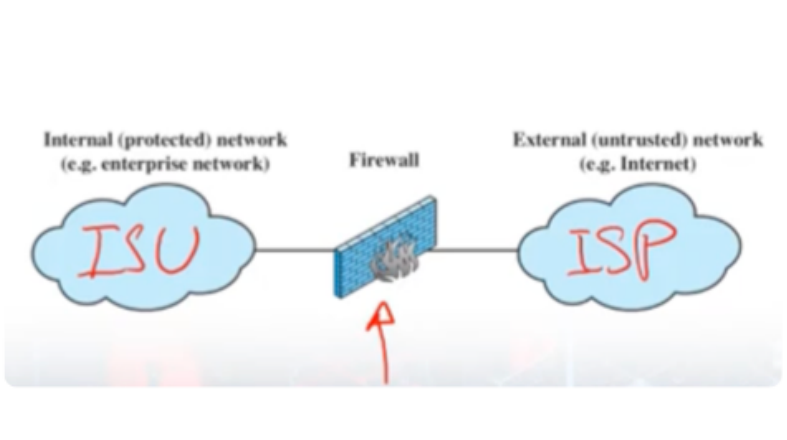
Firewall & Intrusion Prevention System

Intro to firewall

Why we need firewalls?

- used as a perimeter defence
- single entry point to impose security
  - & auditing
- means to protect LAN's

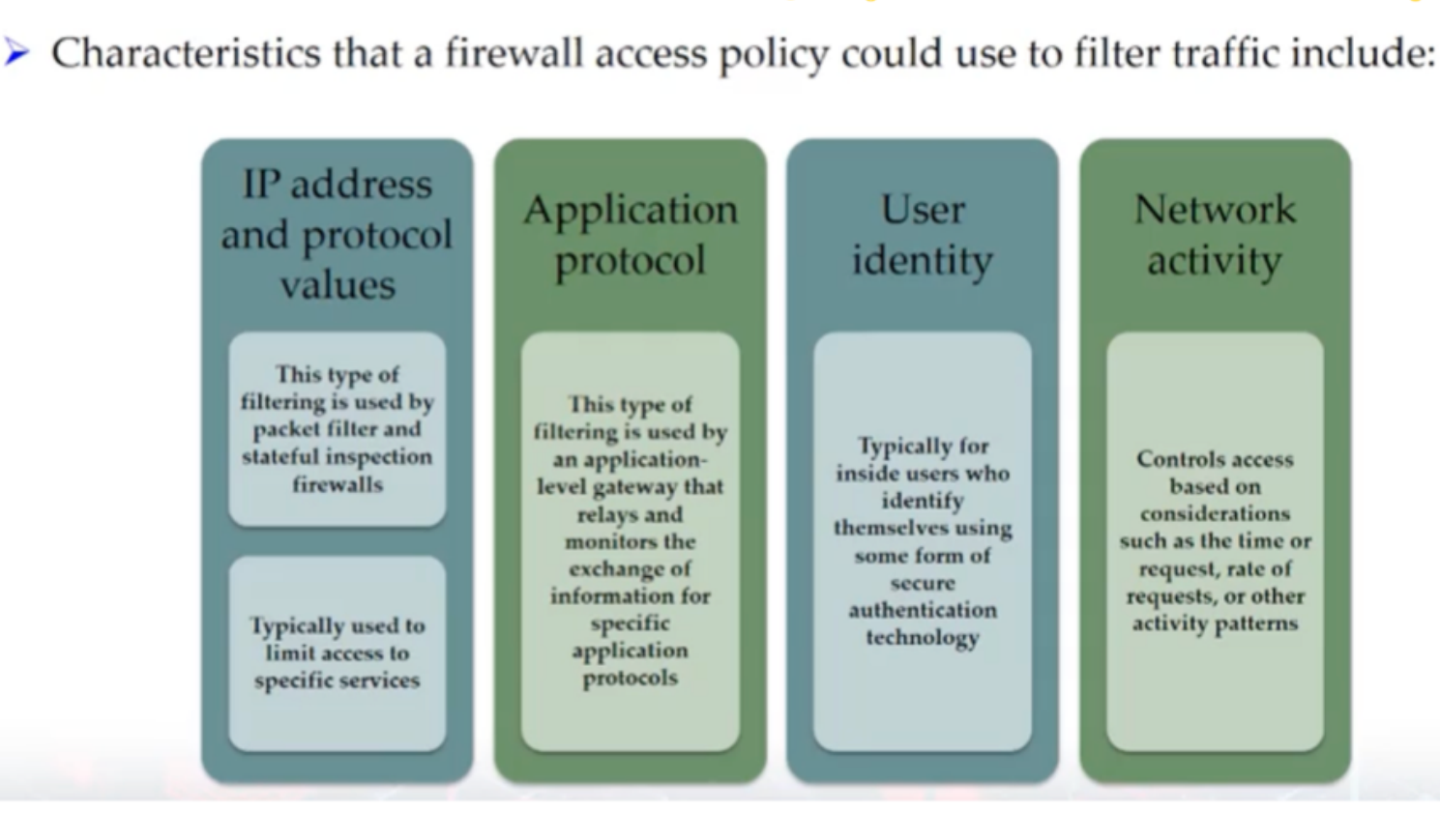

Internal (protected) network
(e.g. enterprise network)
Firewall
External (untrusted) network
(e.g. Internet)
ISU
ISP

Location of fw

- for home network (2-3 computers)
  - on router
- for large organization (1000 computers)
  - on router

Fw characteristics

- Design goals
  - all traffic in to out must pass thru
  - only authorized traffic defined in local security policy allowed
  - fw itself is immune to penentration
- General Techniques
  - service control ; filter based on IP / port #
  - direction control ; to internal LAN, to external internet
  - user control ; student vs faculty
  - behavior control ; filter email with spam



➢ Characteristics that a firewall access policy could use to filter traffic include:

IP address and protocol values	Application protocol	User identity	Network activity
This type of filtering is used by packet filter and stateful inspection firewalls Typically used to limit access to specific services	This type of filtering is used by an application-level gateway that relays and monitors the exchange of information for specific application protocols	Typically for inside users who identify themselves using some form of secure authentication technology	Controls access based on considerations such as the time or request, rate of requests, or other activity patterns

Capabilities & Limitations

- defines single choke point
- provides location for monitoring security events
- convenient platform for several internet functions that are not security related

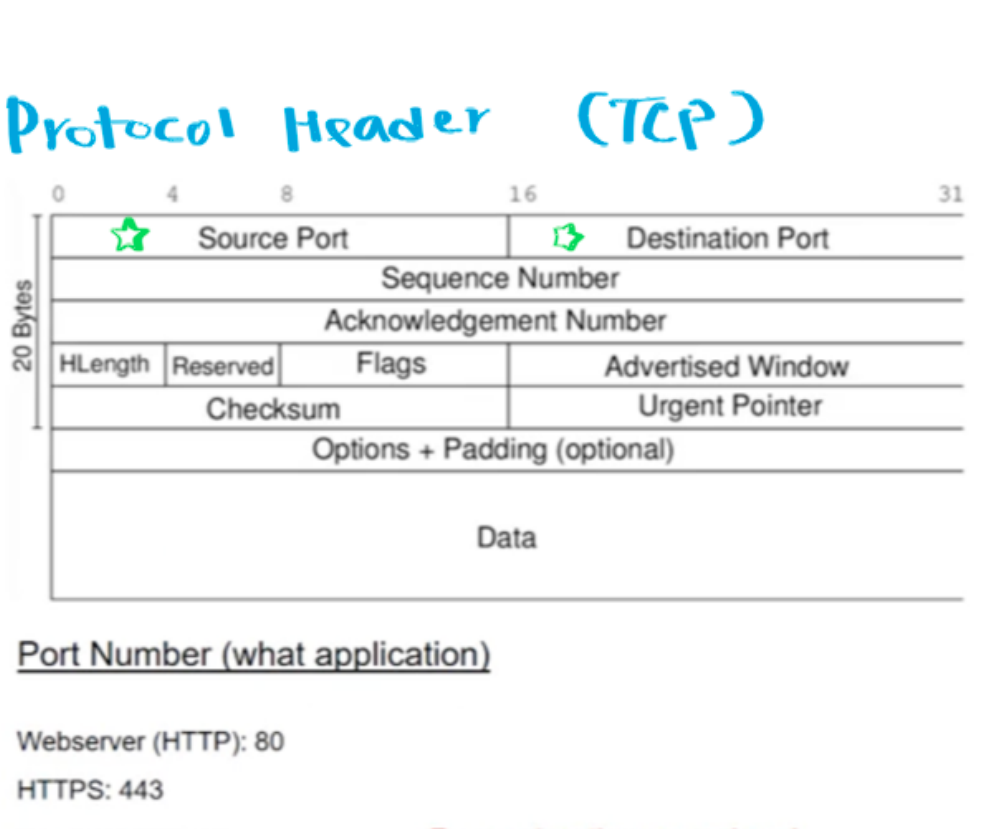
- cannot protect against attacks bypassing fw
- may not fully protect against internal threats
- laptop, phone, or USB may be infected outside then brought inside network

Types of fw

- packet filtering
  - accept/reject based on protocol headers
- stateful packet inspection
  - adds state info on what happened previously to packet filtering fw
- application proxy
  - relay for application proxy
- circuit level proxy
  - relay for transport connections

Normally fw implemented on router

Protocol Header (TCP)



0 4 8	16 31
Source Port	Destination Port
Sequence Number	
Acknowledgement Number	
HLength · Reserved · Flags	Advertised Window
Checksum	Urgent Pointer
Options + Padding (optional)	
Data	

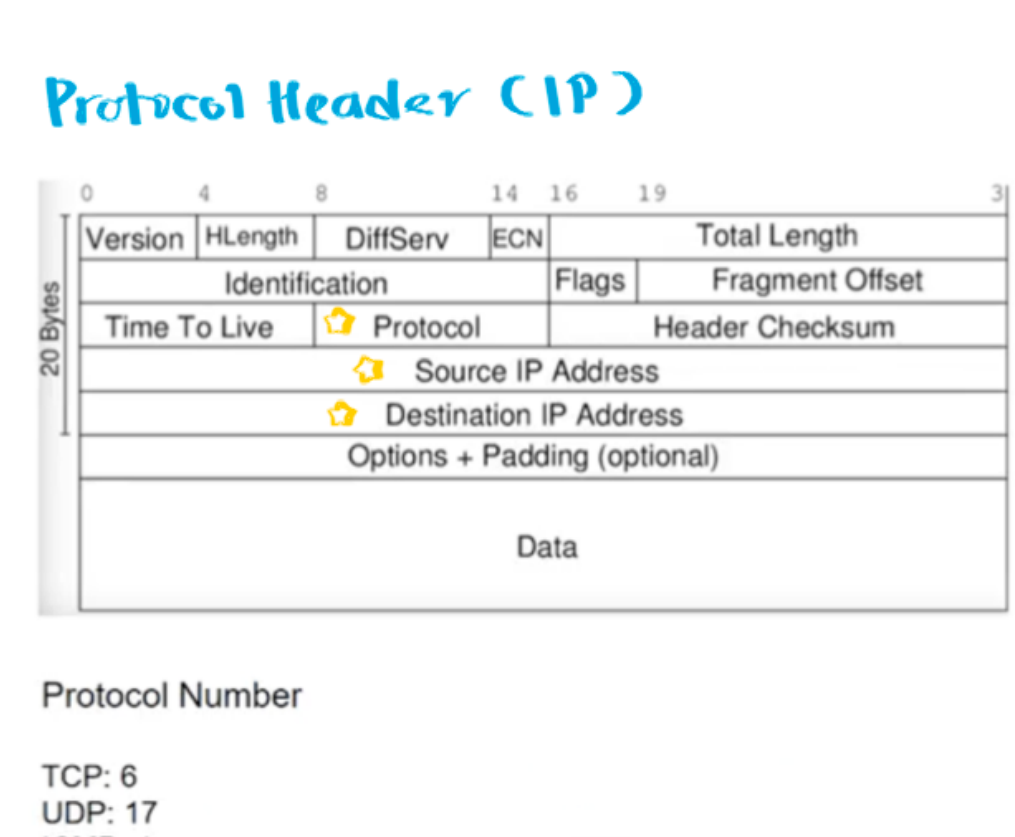
20 Bytes

Port Number (what application)

Webserver (HTTP): 80
HTTPS: 443
Email (SMTP): 25
SSH: 22
TelNet: 23

Remember these numbers!

Protocol Header (IP)



Version	HLength	DiffServ	ECN	Total Length
Identification			Flags	Fragment Offset
Time To Live	Protocol			Header Checksum
Source IP Address				
Destination IP Address				
Options + Padding (optional)				
Data				

0 4 8 14 16 19 31 · 20 Bytes

Protocol Number

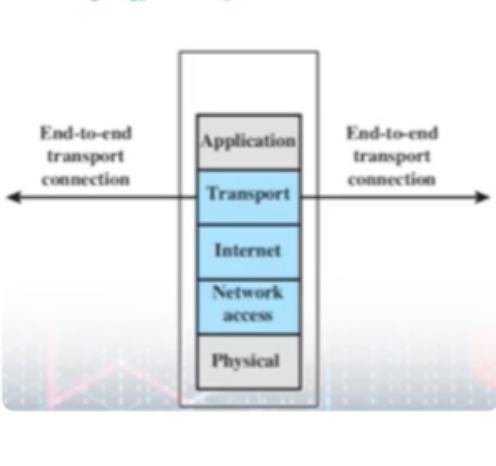
TCP: 6
UDP: 17
ICMP: 1

Remember these numbers!

Packet Filtering FW (Part 1)

What is packet filtering fw?

- security policy implemented by set of rules
- rules define which packets can pass
- fw inspects arriving packets (all direction) against rule set
- default policies : action for packets when no rule matches
  - accept (allow, forward)
  - drop (reject, discard) ☆ recommended


End-to-end transport connection
Application
Transport
Internet
Network access
Physical
End-to-end transport connection

Packet Filtering Rules

- packet info
  - IP addr
  - port #
  - protocol
  - fw interface
  - others
- rules
  - conditions defined using packet info, direction
  - wildcards (*) support to match multiple values
  - actions typically accept or drop
  - list of rules processed in order

Ex of Packet Filtering Fw

- sw
  - in OS
    iptables (linux), ipfw (mac), pf (BSD), windows fw
  - standalone sw
    comodo, norton, check point
- hw
  - fw included in most routers
  - dedicated hw : Cisco ASA/PIX, Dell SonicWALL

ping : sends req to device ⟶ then receives response

Packet Filtering FW (Part 2)

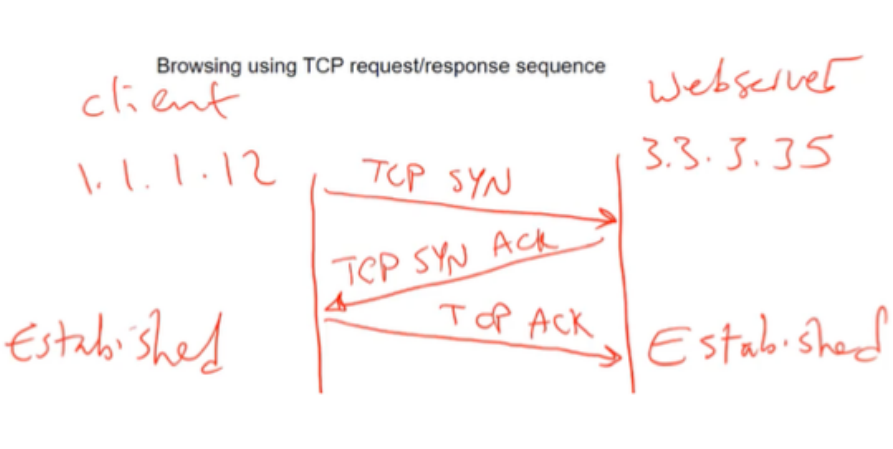
Issues with Packet Filtering Fw

- advantages : simplicity, transparent to users, very fast
- disadvantages ; limited logging, do not support advanced user auth, vulnerable to attacks on TCP/IP bugs, improper config, if attack based on content inside then it wont be detected

Allow/Deny Default Policies

- security pov
  - default deny better
- from functional user pov
  - default allow better

TCP/webserver communications



☆ 3 way handshake

Stateful Packet Inspection FW

Drawback of Packet Filtering fw

- rule used one way is fine, but we need to send TCP SYN ACK back so we need two way — this can be spoofed

Stateful Packet Inspection fw

- remembers packets based on connection requests/communication
- need to store info (overhead)
- happens at transport layer

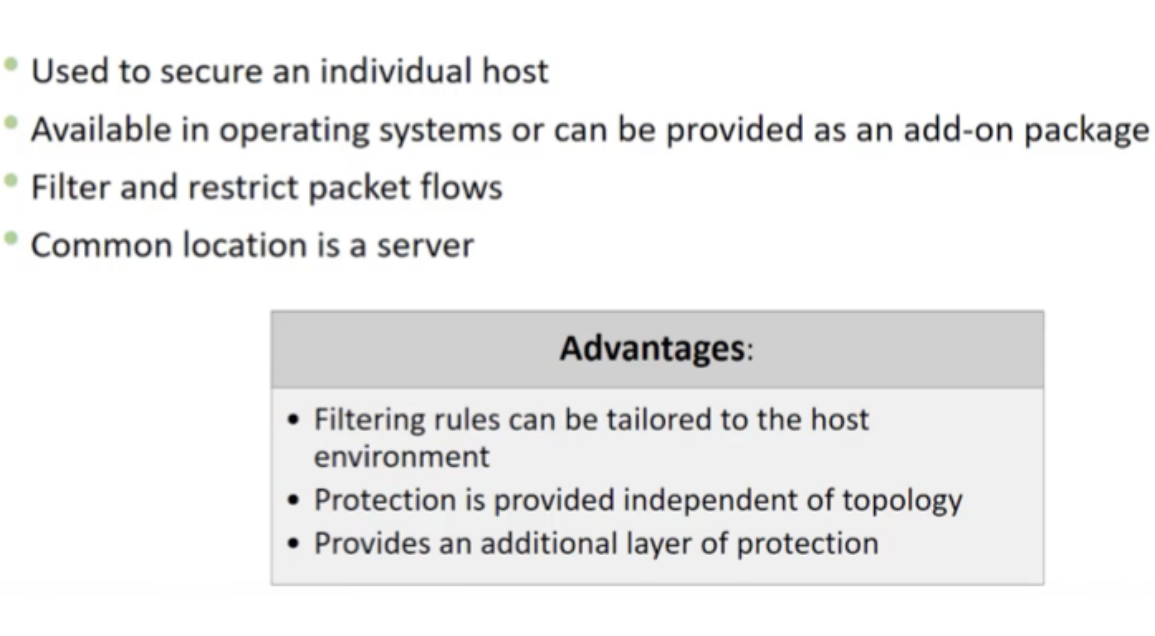
Other types of fw & locations

Application-level gateway (proxy fw)

- more secure than packet filters
- additional processing overhead on each connection
- works on application layer

Circuit-level gateway (also a proxy fw)

- works on transport layer, rest is same as above
  - used when inside users are trusted

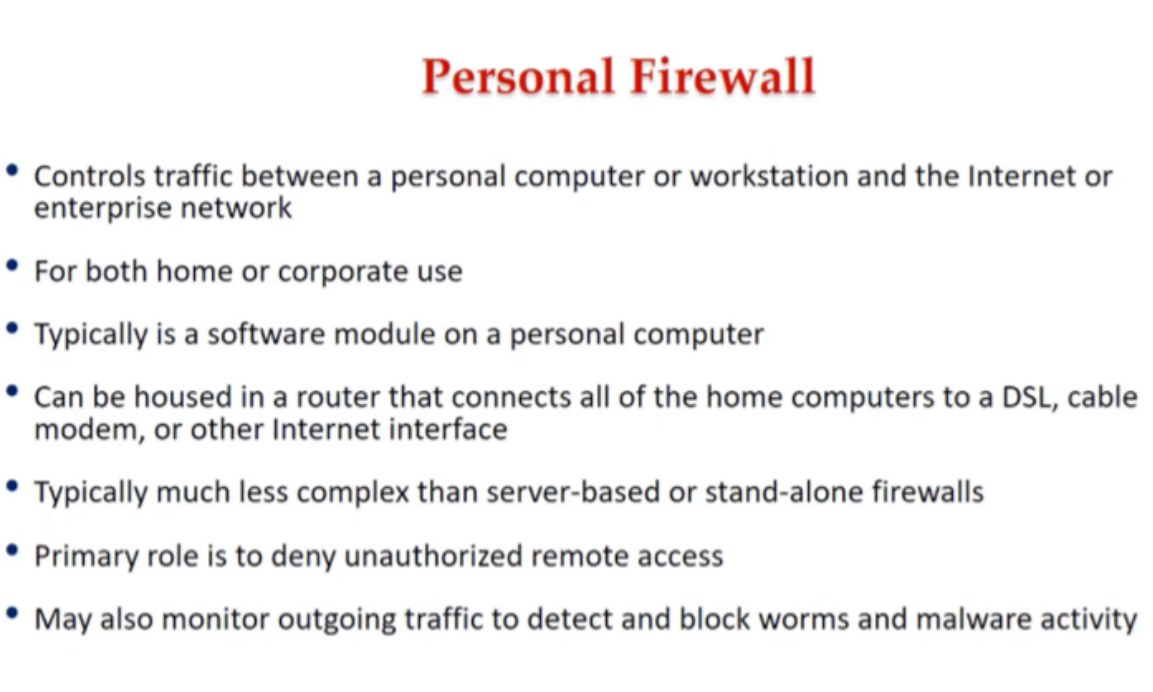


Host-Based Firewalls

- Used to secure an individual host
- Available in operating systems or can be provided as an add-on package
- Filter and restrict packet flows
- Common location is a server

Advantages:

- Filtering rules can be tailored to the host environment
- Protection is provided independent of topology
- Provides an additional layer of protection



Personal Firewall

- Controls traffic between a personal computer or workstation and the Internet or enterprise network
- For both home or corporate use
- Typically is a software module on a personal computer
- Can be housed in a router that connects all of the home computers to a DSL, cable modem, or other Internet interface
- Typically much less complex than server-based or stand-alone firewalls
- Primary role is to deny unauthorized remote access
- May also monitor outgoing traffic to detect and block worms and malware activity

Firewall location

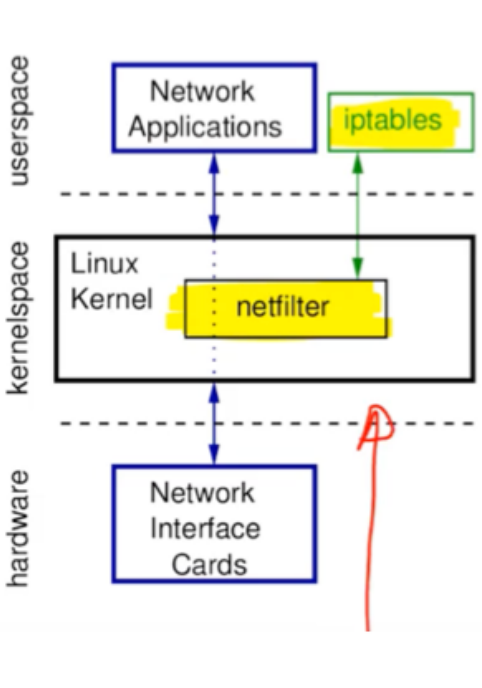
- common to separate internal nw into two zones
  - public facing serves
  - end user computers & internal servers

public facing servers put in DMZ

Firewalls with IP Tables (Part 1)

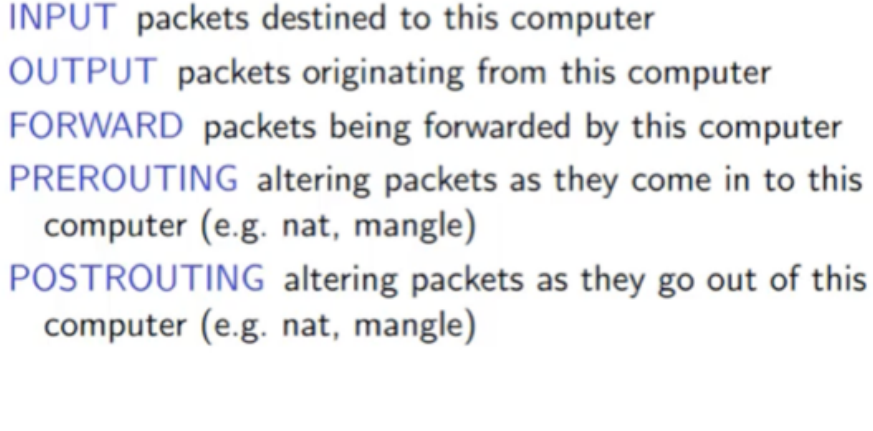
Linux, Netfilter & IPTables

- netfilter : fw in linux system
- iptables : write rules for netfilter
- need to have admin access for above



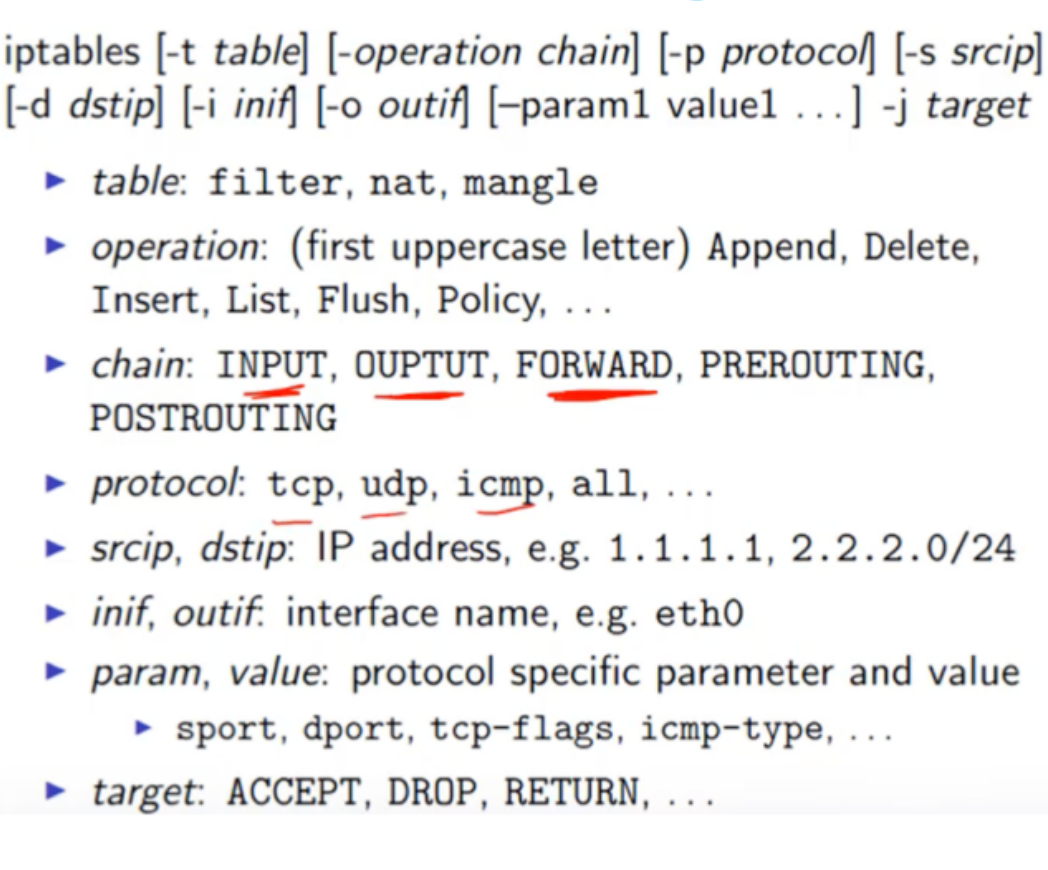
IP Tables Concepts (tables, chains, rules)

- allow you to set rules
- tables contain chains ⟶ chains contain packet filter rules (accept, drop, return)



INPUT packets destined to this computer
OUTPUT packets originating from this computer
FORWARD packets being forwarded by this computer
PREROUTING altering packets as they come in to this computer (e.g. nat, mangle)
POSTROUTING altering packets as they go out of this computer (e.g. nat, mangle)

Common IP Tables Syntax



iptables [-t *table*] [-*operation chain*] [-p *protocol*] [-s *srcip*] [-d *dstip*] [-i *inif*] [-o *outif*] [–param1 value1 . . .] -j *target*

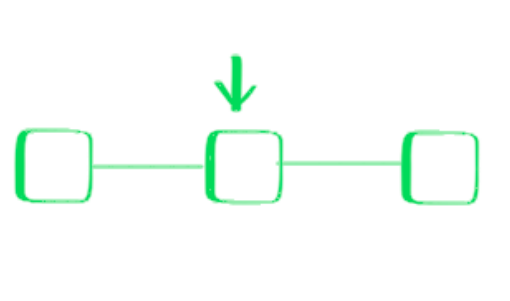
- *table*: `filter`, `nat`, `mangle`
- *operation*: (first uppercase letter) Append, Delete, Insert, List, Flush, Policy, . . .
- *chain*: `INPUT`, `OUPTUT`, `FORWARD`, `PREROUTING`, `POSTROUTING`
- *protocol*: `tcp`, `udp`, `icmp`, `all`, . . .
- *srcip*, *dstip*: IP address, e.g. `1.1.1.1`, `2.2.2.0/24`
- *inif*, *outif*: interface name, e.g. `eth0`
- *param*, *value*: protocol specific parameter and value
  - `sport`, `dport`, `tcp-flags`, `icmp-type`, . . .
- *target*: `ACCEPT`, `DROP`, `RETURN`, . . .

Commands

- view rules
  - `iptables -L -n` or `iptables -L FORWARD -v`
- drop tcp
  - `sudo iptables -A FORWARD -p tcp -j DROP`
- block packets on eth0 and destined for 10.10.1.1
  - `sudo iptables -A FORWARD -i eth0 -d 10.10.1.1 -j DROP`

Firewalls with IP Tables (Part 2)

- Forward is used for middle device



Intrusion Prevention System

IPS

- extension to IDS that also has capability to attempt to block or prevent

Host-Based IPS (HIPS)

- can be signature or anomaly based to identify attacks
- examples of issues it addresses
  - mods to system resources
  - privilege escalation exploits
  - buffer overflow
- can be used on personal computer or servers
- has extra feature called sandbox
  - takes .exe file and executes it in isolated env

Network-Based IPS (NIPS)

- same as HIPS, can use anomaly & signature based
- ability to modify or drop packets + tear down TCP conn
- provide flow data protection

Digital Immune System

- comprehensive defence against malware
- success depends on malware analysis to detect new & innovative malware strains

Snort Inline

- enables snort to be a IPS
- includes a replace option allowing snort to modify packets instead of dropping
  - useful for honey pots
  - attackers see failure but dont know why